

TP2 – Investigation OSINT Autonome : Analyse de Surface d'Attaque

Introduction

Vous êtes **analyste OSINT junior** dans une société de conseil en cybersécurité. Votre manager vous confie une **mission de reconnaissance passive** pour un client potentiel qui souhaite évaluer son exposition publique avant un audit de sécurité complet.

Mission : Réaliser une cartographie exhaustive de la surface d'attaque technique du domaine esgi.fr (ou autre domaine d'école/université que vous choisirez) et produire un rapport d'analyse professionnel.

Contraintes réelles :

- Budget limité (outils gratuits uniquement)
- Aucun scan actif autorisé (reconnaissance passive stricte)
- Respect absolu du cadre légal (pas d'exploitation, pas d'intrusion)

Phase 1 : Planification de la mission

Objectifs à définir **VOUS-MÊME**

Avant de commencer, rédigez un plan de reconnaissance détaillant :

Vos objectifs précis (au minimum 5 objectifs mesurables) :

- Exemple : "Identifier au moins 15 sous-domaines actifs"
- Exemple : "Cartographier l'infrastructure d'hébergement"
- **À VOUS** : Définissez 3 autres objectifs pertinents

Les questions de recherche auxquelles vous devez répondre :

- Quelle est la technologie stack utilisée ?
- Y a-t-il des services exposés non sécurisés ?
- Quelles informations sensibles sont indexées publiquement ?
- **À VOUS** : Formulez 5 autres questions pertinentes

Choix d'outils justifié :

- Pour chaque objectif, listez 2-3 outils que vous comptez utiliser
- **JUSTIFIEZ** pourquoi vous choisissez ces outils plutôt que d'autres
- Anticipez leurs limites

Livrable attendus :

- **Document de planification (1-2 pages) à inclure en introduction du rapport.**

Phase 2 : Investigation technique autonome (2h30)

Mission ouverte : À vous de jouer !

Contrairement à un TP guidé, AUCUNE procédure pas-à-pas ne vous est fournie.

Vous devez :

- Choisir vos outils parmi ceux évoqués en cours ou que vous découvrirez
- Structurer votre investigation selon VOTRE méthodologie
- Documenter chaque découverte avec captures et analyses
- Pivoter : une information en amène une autre, exploitez les connexions

Axes d'investigation obligatoires

Vous devez couvrir au minimum ces 5 axes (mais vous pouvez en ajouter) :

Axe 1 : Reconnaissance du domaine et infrastructure DNS

Objectif : Cartographier l'infrastructure de nommage

Questions à résoudre :

- Qui possède le domaine ? Quand a-t-il été enregistré ?
- Quels sont les nameservers ? Chez quel hébergeur ?
- Quels sont les enregistrements DNS critiques (MX, TXT, SPF, DMARC) ?
- Y a-t-il des configurations DNS qui révèlent des vulnérabilités ?

Livrables attendus :

- Fiche technique complète du domaine
- Analyse de la politique de messagerie (SPF/DMARC)
- Schéma de l'infrastructure DNS
- **Analyse critique** : Quels risques identifiez-vous ?

Axe 2 : Énumération exhaustive des sous-domaines

Objectif : Découvrir TOUS les sous-domaines accessibles

Défi : Trouvez au moins 20 sous-domaines différents en combinant plusieurs techniques

Techniques à combiner (à vous de choisir les outils) :

- Recherche passive (certificats SSL, moteurs de recherche)
- Agrégation de sources (theHarvester, Subfinder, Amass...)
- Recherche manuelle ciblée (Google Dorks sur le domaine)
- Analyse de code source et robots.txt

Livrables attendus :

- Tableau Excel/CSV avec TOUS les sous-domaines trouvés
- Colonnes : Sous-domaine | IP | Status HTTP | Technologie | Accessibilité | Risque
- Pour chaque sous-domaine, testez manuellement l'accessibilité
- **Analyse** : Identifiez les sous-domaines à risque (dev, test, admin, staging...)

Axe 3 : Fingerprinting technologique et versions

Objectif : Identifier précisément la stack technique

À découvrir :

- Serveur web (nginx, Apache, IIS...) et sa VERSION
- CMS utilisé (WordPress, Drupal...) et sa VERSION
- Frameworks (React, Angular, Vue...) et leurs VERSIONS CDN et services tiers (Cloudflare, Google Analytics...) Langages backend détectables
- Bibliothèques JavaScript chargées

Livrables attendus :

- Tableau de la stack technique complète avec versions
- Pour chaque technologie/version, vérifiez s'il existe des CVE connues
- **Analyse de risque** : Les versions sont-elles à jour ? Y a-t-il des vulnérabilités publiques ?

Axe 4 : Services exposés et cartographie réseau

Objectif : Identifier tous les services accessibles publiquement

À investiguer via Shodan/Censys/Criminal IP :

- Toutes les IP associées au domaine
- Ports ouverts sur chaque IP Bannières de services
- Certificats SSL/TLS (validité, émetteur, couverture)
- Services inhabituels (FTP, SSH, RDP, bases de données...)

Livrables attendus :

- Cartographie réseau (schéma ou tableau)
- Pour chaque service : Port | Protocole | Version | Score de risque
- **Analyse critique** : Services légitimes ou oubliés ? Risques d'exposition ?

Axe 5 : Recherche de fuites d'informations

Objectif : Identifier les informations sensibles exposées

Investigations à mener :

- Google Dorks avancés (documents, configurations, logs...)
- Recherche de credentials dans les fuites (Have I Been Pwned sur domaine courriel)
- Analyse de métadonnées de documents publics (PDF, DOCX...)
- Recherche de courriels et de profils associés au domaine
- Code source GitHub/GitLab lié au domaine
- Comptes de réseaux sociaux officiels et ce qu'ils révèlent

Livrables attendus :

- Liste de toutes les fuites identifiées avec niveau de criticité
- Exemples de documents/informations sensibles (anonymisés dans le rapport)
- **Recommandations** : Comment limiter l'exposition ?

Axes bonus (optionnel mais valorisé)

Si vous avez le temps, investiguez également :

Axe 6 : Intelligence sur l'organisation

- Qui travaille pour cette organisation ? (LinkedIn, réseaux sociaux)
- Quelles technologies sont mentionnées dans les offres d'emploi ?
- Y a-t-il des employés qui divulguent des informations sensibles en ligne ? Événements publics, conférences où l'organisation est mentionnée ?

Axe 7 : Analyse de la posture sécurité

- Headers HTTP de sécurité présents ? (CSP, HSTS, X-Frame-Options...)
- Politique HTTPS (grade SSL Labs) ?
- Présence de security.txt ou bug bounty program ?

Phase 3 : Analyse et corrélation (30 min)

Une fois la collecte terminée, **analysez et corrélerez** vos découvertes :

Questions d'analyse critique

1. **Cohérence de l'infrastructure** : L'infrastructure est-elle homogène ou dispersée ?
2. **Niveau de maturité sécurité** : L'organisation semble-t-elle mature en cybersécurité ?
3. **Surface d'attaque** : Quelle est l'ampleur de l'exposition publique ?
4. **Vecteurs d'attaque identifiés** : Quels seraient les 3 vecteurs d'attaque les plus probables ?
5. **Comparaison d'outils** : Quel outil vous a fourni le plus d'informations pertinentes ? Lequel était le moins utile ?

Matrice de synthèse

Créez une **matrice de couverture** montrant quels outils ont découvert quelles informations :

Information découverte	Outil A	Outil B	Outil C	Manuel	Validation
Sous-domaine X	✓	X	✓	X	Confirmé
Service Y port Z	X	✓	X	✓	Confirmé

Conseils méthodologiques pour l'autonomie

Comment aborder ce TP ?

1. **Ne cherchez pas la bonne méthode** : Il n'y en a pas ! Votre approche personnelle est valorisée.
2. **Documentez tout** : Chaque commande, chaque outil, chaque découverte. Prenez des notes continues.
3. **Itérez** : Si un outil ne donne rien, pivotez vers un autre. Si vous trouvez un sous-domaine intéressant, creusez-le.
4. **Croisez systématiquement** : Ne faites jamais confiance à une seule source. Validez par au moins 2 outils.
5. **Pensez comme un attaquant** : À chaque découverte, demandez-vous "Comment un attaquant pourrait exploiter cela ?"
6. **Restez éthique** : Documentez pourquoi vous ne dépassez pas certaines limites.

Ressources disponibles

- Support de cours
- Documentation des outils (GitHub, sites officiels)
- Tutoriels en ligne (mais adaptez-les, ne copiez pas)
- Communauté OSINT (forums, Discord, Twitter)
- Guides méthodologiques (OWASP, NIST, SANS)

Interdit :

- Partager votre cible avec d'autres étudiants avant le rendu
- Utiliser des outils qui font du scan actif/intrusif
- Exploiter les vulnérabilités découvertes
- Accéder à des zones privées ou authentifiées

Cas d'usages professionnels

Ce TP simule des situations réelles d'analyste OSINT

- **Cabinet de conseil** : Due diligence avant acquisition d'entreprise
- **Équipe Red Team** : Phase de reconnaissance avant test d'intrusion
- **SOC/CERT** : Cartographie de sa propre exposition pour défense proactive
- **Threat Intelligence** : Profilage d'une organisation cible d'attaquants

Votre rapport doit avoir le niveau de qualité d'un livrable professionnel facturé à un client

Ce TP exigeant vous place en situation professionnelle réelle. Votre capacité à structurer une investigation complexe, à faire preuve d'initiative et à produire une analyse de qualité sera déterminante pour votre évaluation et votre future carrière en cybersécurité

Bon travail !
